

P-SGSI-09: Metodología de Auditoría Basada en Riesgos y Procesos

Universidad Nacional del Centro del Perú (UNCP)

SGSI ISO/IEC 27001:2022

Organización: Universidad Nacional del Centro del Perú (UNCP) **Versión:** 1.0 (Integración ISO 31000 / MAGERIT / NIST CSF) **Norma:** ISO/IEC 27001:2022 (Cláusula 9.2)

1. Enfoque Estratégico

La UNCP abandona el modelo de auditoría estática anual por un enfoque de **Auditoría Continua y Basada en Riesgos**. El objetivo no es solo verificar el cumplimiento (ISO 27001), sino evaluar la resiliencia operativa (NIST) y el valor de los activos (MAGERIT).

2. Criterios de Evaluación y Priorización (Basado en Riesgo)

Siguiendo la **ISO 31000**, la frecuencia y profundidad de la auditoría se determinan mediante el Nivel de Riesgo del proceso.

Nivel de Riesgo (NR)	Frecuencia de Auditoría	Tipo de Auditoría
Crítico (13-16)	Trimestral	Técnica (Pen-testing / Revisión de Configuración)
Alto (9-12)	Semestral	Operativa (Verificación de evidencias y logs)
Medio (5-8)	Anual	Administrativa (Revisión de políticas y registros)
Bajo (1-4)	Bienal	Muestreo aleatorio

3. Estructura del Equipo Auditor (Competencias)

Para garantizar la independencia y competencia, el equipo se conformará por: * **Auditor Líder:** Certificado en ISO 27001 LA, responsable de la estrategia y comunicación con el CGD. * **Auditor Técnico (Ciberseguridad):** Especialista en Nube (Huawei Cloud) y Redes, encargado de validar controles NIST. * **Auditor de Procesos:** Conocedor de la normativa universitaria y administrativa.

4. Flujo del Proceso de Auditoría

1. **Planificación (NIST Identify):** Definición del alcance basado en los activos críticos del inventario MAGERIT.
2. **Ejecución (NIST Protect/Detect):** Pruebas de cumplimiento de controles de la SoA y verificación de la efectividad de la detección de incidentes.
3. **Informe y Comunicación:** Reporte de hallazgos (Conformidades, No Conformidades, Oportunidades de Mejora).
4. **Seguimiento de No Conformidades (NIST Respond/Recover):** Verificación de la implementación de acciones correctivas de manera ágil.

5. Integración con el Dashboard de Seguridad (KRIs)

La auditoría utilizará los **KRIs (Key Risk Indicators)** definidos en el R-SGSI-01 para disparar auditorías no programadas si un indicador (ej. intentos de acceso fallidos) supera el umbral crítico.